CONFIDENTIAL · SECURITY AUDIT

VERSION 6 · RE-REVIEW

Security Audit Tech for Palestine Website

techforpalestine.org · Cloudflare Pages & Workers

This is the **sixth-round re-review**, assessing patches applied after v5 (2026-04-13). Six more findings have been resolved — including the last remaining high-severity item (H-4 rate limiting, confirmed live via WAF testing) and all four medium findings — bringing the total fixed count to **24 of 25 issues**. Only one low-severity finding remains open. The codebase is now in a strong security posture with no critical, high, or medium risk.

V1 ORIGINAL	V2 RE-REVIEW	V3 RE-REVIEW	V4 RE-REVIEW	V5 RE-REVIEW	V6 RE-REVIEW
2026-03-31	2026-04-02	2026-04-06	2026-04-09	2026-04-13	2026-04-14

Executive Summary — v6 Re-review

Delta audit of patches applied after v5 (2026-04-13). Six findings resolved; one low-severity item remains.

24	0	0	0	1	1
TOTAL FIXED	CRITICAL	HIGH	MEDIUM	LOW	OPEN

Remediation progress: 24 of 25 findings resolved (96%)

96%

🎯 Security Milestone — No Critical, High, or Medium Risks Remain

All three original critical findings are resolved. All high-severity findings are resolved, including H-4 (rate limiting) which was confirmed live — Cloudflare WAF returned HTTP 429 responses after the configured threshold during testing. All medium findings (P-2 path traversal, M-6 middleware conflict) are resolved. The codebase now has a single low-severity open item: the QGiv embed script lacks a Subresource Integrity hash.

COMPLETE ISSUE REGISTER — V6 STATUS

ID	Finding	Peak Severity	v6 Status
C-1	API key & account ID in wrangler configs	CRITICAL	Fixed v2
C-2	Unauthenticated membership invite endpoint	CRITICAL	Fixed v2
C-3	Unverified webhook triggers privileged invite	CRITICAL	Fixed v2
N-1	Webhook secret exposed in URL query param	CRITICAL	Fixed v3
N-2	Timing attack on token comparison	HIGH	Fixed v3
H-1	Secret key logged to browser console	HIGH	Fixed v3
H-2	Full donor PII payload echoed in HTTP response	HIGH	Fixed v4
H-3	Middleware caches POST/API responses as public	HIGH	Fixed v3
H-4	No rate limiting on any endpoint	HIGH	Fixed v6 ✓
H-5	Wildcard CORS on all endpoints	HIGH	Fixed v3

ID	Finding	Peak Severity	v6 Status
N-3	membership-invite proxies arbitrary body fields	MEDIUM	Fixed v3
M-1	No CSRF / Origin check on form endpoints	MEDIUM	Fixed v4
M-2	No input format/length validation on forms	MEDIUM	Fixed v4
M-3	getEnv globalThis fallback	MEDIUM	Fixed v3
M-4	Donor PII (email) in server logs	MEDIUM	Fixed v4
M-5	Internal error.message in HTTP responses	MEDIUM	Fixed v3
M-6	Dual middleware conflict — cache-control layer dead code	MEDIUM	Fixed v6 ✓
R-1	PUBLIC_SECRET_KEY in client-side Axios bundle	MEDIUM	Fixed v4
R-2	CSP 'unsafe-inline' defeats XSS protection	MEDIUM	Fixed v4
P-1	project-proxy: Authorization forwarded to any upstream path	MEDIUM	Fixed v5
P-2	project-proxy: dot-segment traversal bypasses prefix check	MEDIUM	Fixed v6 ✓
L-1	Notion DB IDs in wrangler.toml	LOW	Fixed v3
L-3	Image proxy has no authentication	LOW	Fixed v6 ✓
L-4	style-src still uses 'unsafe-inline' in CSP	LOW	Fixed v6 ✓
L-5	project-proxy forwards all browser request headers to upstream	LOW	Fixed v6 ✓
L-2	QGiv embed script loaded without Subresource Integrity hash	LOW	Open

CONFIRMED FIXED SINCE V5 — SIX FINDINGS RESOLVED

- **H-4 — Rate limiting confirmed active**: Cloudflare WAF rate limiting rules were applied to the Pages domain. Live testing confirmed HTTP 429 responses once the threshold was reached (15 requests / 60 seconds / IP on GET endpoints; tighter limits on POST write endpoints). First-run testing showed 14 × 200 followed by 429; subsequent runs within the same window started immediately with 429, confirming the rolling-window enforcement is operating correctly.
- **P-2 — URL normalisation before prefix check** (`src/pages/api/project-proxy.ts:31`): The raw `path` query parameter is now normalised via `new URL(path, "http://localhost").pathname` before the `startsWith("/api/method/")` guard. Dot-segment sequences such as `/api/method/../../api/auth/admin` are resolved to `/api/auth/admin` prior to the check, which then correctly returns 403.
- **M-6 — Middleware restructured with `sequence()`** : The conflicting dual-file layout has been replaced with a clean three-file structure: `src/middleware/cache-control.ts` (cache headers), `src/middleware/csp.ts` (nonce generation and HTMLRewriter), and `src/middleware/index.ts` which composes them with `sequence(cacheControl, csp)` . The old top-level `src/middleware.ts` has been removed. Both middlewares now run on every request in the correct order.
- **L-3 — Image proxy removed entirely**: The `cloudflare-worker/` directory and its `worker.js` were deleted in PR #415 ("Remove Cloudflare Worker image proxy"). No proxy exists to authenticate; the finding is fully closed.
- **L-4 — style-src 'unsafe-inline' replaced with nonce** (`src/middleware/csp.ts:24,48–52`): `style-src` now uses `'nonce-{nonce}'` instead of `'unsafe-inline'` . The HTMLRewriter chain was extended with a `.on("style", ...)` handler that injects the same per-request nonce into every `<style>` tag, mirroring the existing `<script>` treatment. The full CSP now has no `'unsafe-inline'` directives on either script or style sources.
- **L-5 — Explicit header allowlist in project-proxy** (`src/pages/api/project-proxy.ts:44–50`): The `new Headers(request.headers)` copy-all approach was replaced with an explicit `FORWARD_HEADERS` array (`content-type` , `accept` , `accept-language` , `accept-encoding`). Only those four headers are forwarded to the upstream API. `Cookie` , `X-Forwarded-For` , `CF-Connecting-IP` , and all other browser-supplied headers are now silently dropped before the upstream request is made.

REMAINING OPEN FINDING

LOW L-2

QGiv Payment Embed Script Loaded Without Subresource Integrity — Open Since v1

File: src/components/MembershipPage.tsx:41–42 **OWASP:** A08:2021 – Software & Data Integrity Failures

The QGiv embed script is dynamically injected into the DOM without an `integrity` attribute. A supply-chain compromise of QGiv's CDN could deliver malicious JavaScript into the payment context. The script URL and injection point are:

```
// MembershipPage.tsx:41-42 — no integrity check
script.src = "https://secure.qgiv.com/resources/core/js/embed.js";
// script.integrity is never set
```

FIX — COMPUTE HASH AND ADD INTEGRITY ATTRIBUTE

```
# 1. Download the current script and compute its SHA-384 hash
curl -s https://secure.qgiv.com/resources/core/js/embed.js \
  | openssl dgst -sha384 -binary | openssl base64 -A

# 2. Add the hash to the script injection in MembershipPage.tsx
script.integrity = "sha384-<computed-hash>";
script.crossOrigin = "anonymous";
```

Note: SRI hashes lock the script to a specific version. If QGiv updates `embed.js`, the hash must be recomputed and redeployed. Confirm with QGiv whether they version this file or update it in-place — if the latter, coordinate hash updates with their release schedule or consider loading the script via a pinned versioned URL if one is available.

SECURITY POSTURE PROGRESS — ALL ROUNDS

Round	Date	Critical	High	Medium	Low	Total Open	Fixed
v1	2026-03-31	3	5	6	3	17	—
v2	2026-04-02	1	6	7	3	17	3
v3	2026-04-06	0	2	5	3	10	10
v4	2026-04-09	0	1	2	3	6	16
v5	2026-04-13	0	1	2	4	7	17
v6	**2026-04-14**	**0**	**0**	**0**	**1**	**1**	**24**

REMAINING REMEDIATION — V6

Priority	Action	ID	Effort
Backlog	Compute SHA-384 hash of `embed.js` and add `integrity` + `crossOrigin` attributes to the QGiv script injection in `MembershipPage.tsx`. Confirm versioning policy with QGiv first.	L-2	30 min + QGiv coordination

GOOD PRACTICES CONFIRMED IN V6 CODEBASE

- **Middleware architecture is clean and correct:** `src/middleware/index.ts` composes `cacheControl` and `csp` via Astro's `sequence()`. Cache headers are set on every response before the CSP transform runs. No dead code, no silent override risk.
- **Full nonce-based CSP with no unsafe directives:** Both `script-src` and `style-src` use per-request nonces. `HTMLRewriter` injects the nonce into all `<script>` and `<style>` tags. `'unsafe-inline'` is absent from both directives. `'strict-dynamic'` propagates trust to dynamically loaded scripts. `object-src 'none'` and `base-uri 'self'` close common bypass vectors.
- **project-proxy is hardened end-to-end:** Path dot-segments are normalised before the `/api/method/` prefix guard; the guard uses the normalised path for the upstream URL; only four specific headers are forwarded to the upstream API; `Authorization` is added server-side only; hop-by-hop headers are stripped from upstream responses.
- **Rate limiting enforced at CDN edge:** Cloudflare WAF rules block IPs exceeding thresholds on both GET and POST `/api/*` routes. Confirmed live — HTTP 429 returned correctly in rolling-window tests. No application-layer changes needed.

- **Constant-time comparison used on all secret checks:** `constantTimeEqual()` backed by Node.js `timingSafeEqual` is used for the QGiv webhook secret and the membership invite Bearer token. No timing oracle exists in the auth layer.
- **Zero secrets in committed code:** `wrangler.toml` contains no credentials or IDs. All secrets (Notion, Hub API, QGiv, EmailOctopus) are exclusively in the Cloudflare Pages dashboard environment. `.env.example` shows empty values only.
- **All form endpoints validated and origin-locked:** `endorsement-request.ts` and `e4p-pledge-sign.ts` enforce Origin header, validate email (regex), URLs (`new URL()`), field presence, and length limits (≤ 2 000 chars) before any Notion write.
- **Donor PII protected in logs:** All webhook log calls redact full email addresses to `[redacted]@domain.com` , preventing PII exposure in Cloudflare Workers log streams.